Definitions - P

PURPOSE: This document provides a list of words and definitions to clarify Information Specific (IT) terminology contained within the State of Wyoming Policies and Standards.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

- Password: A secret that a Claimant memorizes and uses to authenticate his or her identity. Passwords are typically character strings. (SOURCE: NIST SP 800-63) A protected character string is used to authenticate the identity of a computer system user or to authorize access to system resources. (SOURCE: FIPS 181) A string of characters (letters, numbers, and other symbols) is used to authenticate an identity or to verify access authorization. (SOURCE: FIPS 140-2) A protected/private string of letters, numbers, and/or special characters is used to authenticate an identity or to authorize access to data. (SOURCE: CNSSI-4009)

- Password Cracking: The process of recovering secret passwords stored in a computer system or transmitted over a network. (SOURCE: NIST SP 800-115)

- Password Protected: The ability to protect a file using password access control, protecting the data contents from being viewed with the appropriate viewer unless the proper password is entered. (SOURCE: NIST SP 800-72)

- Patch: An update to an operating system, application, or other software issued specifically to correct particular problems with the software. (SOURCE: NIST SP 800-123)

- Patch Management: The systematic notification, identification, deployment, installation, and verification of operating system and application software code revisions. These revisions are known as patches, hotfixes, and service packs. (SOURCE: CNSSI-4009)

- Payment Card Industry (PCI): The term refers to the Payment Card Industry Security Standards Council, a council originally formed by American Express, Discover Financial Services, JCB, MasterCard Worldwide, and Visa International. The PCI Council formed a body of security standards known as the PCI Data Security Standards, (PCI DSS), and these standards consist of 12 significant requirements including multiple sub requirements that contain numerous directives against which businesses may measure their own payment card security policies, procedures, and guidelines. By complying with qualified assessments of these standards, businesses can become accepted by the PCI Standards Council as compliant with the 12 requirements and thus receive a compliance certification and a listing on the PCI Standards Council website. Compliance efforts and acceptance must be completed on a periodic basis. (SOURCE: Wikipedia)

- Payment Card Industry Data Security Standard (PCI DSS): The Payment Card Industry Data Security Standard (PCI DSS) is a proprietary information security standard for organizations that handle cardholder information for the major debit, credit, prepaid, e-purse, ATM, and POS cards. Defined by the Payment Card Industry Security Standards Council, the standard was created to increase controls around cardholder data to reduce credit card fraud via its exposure. Validation of compliance is performed annually, either by an external Qualified Security Assessor (QSA) that creates a Report on Compliance (ROC) for organizations handling large volumes of transactions or by Self-Assessment Questionnaire (SAQ) for companies handling smaller volumes. (SOURCE: Wikipedia)

- Penetration Testing: A test methodology in which assessors, using all available documentation (e.g., system design, (SOURCE code, manuals) and working under

specific constraints, attempt to circumvent the security features of an information system. (SOURCE: NIST SP 800-53A; NIST SP 800-53; CNSSI4009) Security testing in which evaluators mimic real-world attacks in an attempt to identify ways to circumvent the security features of an application, system, or network. Penetration testing often involves issuing real attacks on real systems and data using the same tools and techniques used by actual attackers. Most penetration tests involve looking for combinations of vulnerabilities on a single system or multiple systems that can be used to gain more access than could be achieved through a single vulnerability. (SOURCE: NIST SP 800-115)

- Personal Identification Number (PIN): A password consisting only of decimal digits. (SOURCE: NIST SP 800-63) A secret that a claimant memorizes and uses to authenticate his or her identity. PINs are generally only decimal digits. (SOURCE: FIPS 201) An alphanumeric code or password is used to authenticate an identity. (SOURCE: FIPS 140-2) A short numeric code is used to confirm identity. (SOURCE: CNSSI-4009)

- Personal Information (PI): An individual's first name or first initial and last name linked with any one or more of the following data elements: 1. Social Security number; 2. Driver's license number or State identification card number; or 3. Account number or credit or debit card number, in combination with any required security code, access code, or password that would permit access to an individual's financial account. Dissociated data that, if linked, would constitute personal information is personal information if the means to link the dissociated data were accessed in connection with access to the dissociated data.

- Personally Identifiable Information (PII): Information that can be used to distinguish or trace an individual's identity, such as their name, social security number, biometric records, etc., alone or when combined with other personal or identifying information that is linked or linkable to a specific individual, such as date and place of birth, mother’s maiden name, etc. (SOURCE: CNSSI-4009) Any information about an individual maintained by an agency, including a. any information that can be used to distinguish or trace an individual‘s identity, such as name, social security number, date and place of birth, mother‘s maiden name, or biometric records; and b. any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information.

(SOURCE: NIST SP 800-122)

- Phishing: Tricking individuals into disclosing sensitive personal information through deceptive computer-based means. (SOURCE: NIST SP 800-83) Deceiving individuals into disclosing sensitive personal information through deceptive computer-based means. (SOURCE: CNSSI-4009) A digital form of social engineering that uses authentic-looking—but bogus—emails to request information from users or direct them to a fake Web site that requests information. (SOURCE: NIST SP 800-115)

- Plaintext: Data input to the Cipher or output from the Inverse Cipher. (SOURCE: FIPS 197) Intelligible data that has meaning and can be understood without the application of decryption. (SOURCE: NIST SP 800-21) Unencrypted information. (SOURCE: CNSSI-4009)

- Port Scanning: Using a program to remotely determine which ports on a system are open (e.g., whether systems allow connections through those ports). (SOURCE: CNSSI-4009)

- Portable Storage Device: An information system component that can be inserted into and removed from an information system and that is used to store data or information (e.g., text, video, audio, and/or image data). Such components are typically implemented on magnetic, optical, or solid-state devices (e.g., floppy disks, compact/digital video disks, flash/thumb drives, external hard disk drives, and flash memory cards/drives that contain non-volatile memory). (SOURCE: NIST)

- Portal: A high-level remote access architecture that is based on a server that offers teleworkers access to one or more applications through a single centralized interface. (SOURCE: NIST SP 800-46)

- Privacy: Restricting access to subscriber or Relying Party information in accordance with federal law and agency policy. (SOURCE: NIST SP 800-32) Freedom from unauthorized intrusion or disclosure of information about an individual (SOURCE: ISACA)

- Privacy Impact Assessment (PIA): An analysis of how information is handled: 1. to ensure handling conforms to applicable legal, regulatory, and policy requirements

regarding privacy; 2. to determine the risks and effects of collecting, maintaining, and disseminating information in identifiable form in an electronic information system; and 3. to examine and evaluate protections and alternative processes for handling information to mitigate potential privacy risks. (SOURCE: NIST SP 800-53; NIST SP 800-18; NIST SP 800-122; CNSSI-4009; OMB Memorandum 03-22)

- Privileged User: A user that is authorized (and, therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform. (SOURCE: NIST SP 800-53; CNSSI-4009)

- Probe: A technique that attempts to access a system to learn something about the system. (SOURCE: CNSSI-4009)

- Production Environment (System): The environment that is actively being used by stakeholders and would have a significant business impact if non-operational

- Project - Isolated segment of the source code repository that is dedicated to the source code manager for their use.

- Protected Health Information (PHI): The term Protected Health Information, is composed from two definitions in Section 1171 of Part C of Subtitle F of Public Law 104-191 (August 21, 1996): Health Insurance Portability and Accountability Act of 1996: Administrative Simplification. These statutory definitions are of health information and individually identifiable health information. Health information means any information, whether oral or recorded in any form or medium, that: (a) is created or received by a health care provider, health plan, public health authority, employer, life insurer, school or university, or health care clearinghouse; and (b) relates to the past, present, or future physical or mental health or condition of any individual, the provision of health care to an individual, or the past, present, or future payment for the provision of health care to an individual. Individually Identifiable Health Information is information that is a subset of health information, including demographic information collected from an individual, and: (a) Is created or received by a health care provider, health plan, employer, or health care clearinghouse; and (b) Relates to the past, present, or future physical or mental health or condition of an individual; the provision of health care to an individual; or the past, present, or future payment for the provision of health care to an individual; and (i) That identifies the individual; or (ii) With respect to which there is

a reasonable basis to believe the information can be used to identify the individual. Protected Health Information means individually identifiable health information [defined above]: a) Except as provided in paragraph (b) of this definition, that is: (i) Transmitted by electronic media; (ii) Maintained in electronic media; or (iii) Transmitted or maintained in any other form or medium. (b) Protected health information excludes individually identifiable health information in: (i) Education records covered by the Family Educational Rights and Privacy Act, as amended, 20 U.S.C. 1232g; (ii) Records described at 20 U.S.C. 1232g(a)(4)(B)(iv); and (iii) Employment records held by a covered affiliate in its role as employer. The HIPAA Privacy Rule covers protected health information in any medium while the HIPAA Security Rule covers electronic protected health information. With those definitions in place, the question becomes: what elements comprise protected health information such that if they were removed, items (i) and (ii) of (b) in the definition of individually identifiable health information would not be obtained. The answer is in the de-identification standard and its two implementation specifications of the HIPAA Privacy Rule [45 CFR 164.514]: (a) Standard: de-identification of protected health information. Health information [defined above] that does not identify an individual and with respect to which there is no reasonable basis to believe that the information can be used to identify an individual is not individually identifiable health information. (b) Implementation specifications: requirements for de-identification of protected health information. A covered affiliate may determine that health information is not individually identifiable health information only if: 1) A person with appropriate knowledge of and experience with generally accepted statistical and scientific principles and methods for rendering information not individually identifiable: (i) Applying such principles and methods, determines that the risk is very small that the information could be used, alone or in combination with other reasonably available information, by an anticipated recipient to identify an individual who is subject of the information; and (ii) Documents the methods and results of the analysis that justify such determination; or 2) (i) The following identifiers of the individual or of relatives, employers, or household members of the individual, are removed: a. Names; b. All geographic subdivisions smaller than a State, including street address, city, county, precinct, zip code, and their equivalent geocodes, except for the initial three digits of a zip code if, according to the current publicly available data from the Bureau of the Census: (1) The geographic unit formed by combining all zip codes with the same three initial digits contains more than 20,000 people; and (2) The initial three digits of a zip code for all such geographic units containing

20,000 or fewer people is changed to 000. c. All elements of dates (except year) for dates directly related to an individual, including birth date, admission date,, discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may be aggregated into a single category of age 90 or older; d. Telephone numbers; e. Fax numbers; f. Electronic mail addresses; g. Social security numbers; h. Medical record numbers; i. Health plan beneficiary numbers; j. Account numbers; k. Certificate/license numbers; l. Vehicle identifiers and serial numbers, including license plate numbers; m. Device identifiers and serial numbers; n. Web Universal Resource Locators (URLs); o. Internet Protocol (IP) address numbers; p. Biometric identifiers, including finger and voice prints; q. Full face photographic images and any comparable images; and r. Any other unique identifying number, characteristic, or code, except as permitted by paragraph (c) of this section; and (ii) The covered affiliate does not have actual knowledge that the information could be used alone or in combination with other information to identify an individual who is a subject of the information. (iii) Implementation specifications: re-identification. A covered affiliate may assign a code or other means of record identification to allow information de-identified under this section to be re-identified by the covered affiliate, provided that: a. Derivation. The code or other means of record identification is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and b. Security. The covered affiliate does not use or disclose the code or other means of record identification for any other purpose, and does not disclose the mechanism for re-identification. (SOURCE: HIPAA)

- Public or Low Sensitivity. Public information poses no risk to the State if made generally available.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	SUBMITTED BY	APPROVED BY	ISSUED DATE	EFFECTIVE DATE

REVISIONS		
LAST REVISION DATE	LAST REVISED BY	LAST APPROVED BY

REVIEWS		
LAST REVIEW DATE	LAST REVIEWED BY	NEXT REVIEW DATE